

NexDay (RetailHub)

Cloud-Native E-Commerce Telemetry Lakehouse & Real-Time AI Fraud Defense Ecosystem

MASTER ACADEMIC & TECHNICAL PROJECT REPORT

Institution:	ST JOSEPH UNIVERSITY
Department:	Department of Big Data Analytics & Computer Science
Project Title:	NexDay (RetailHub) Cloud Lakehouse & AI Security Platform
Academic Session:	2025 – 2026
Submission Date:	October 2026

PROJECT TEAM MEMBERS & REGISTER NUMBERS

Register No.	Student Name	Core Project Role & Responsibilities
252BDA18	PRITHVISH WILLIAM	Streaming Security (PySpark FraudGuard, 15 Rules, Gemini AI) & Apache Airflow 3.1.0 Orchestration
252BDA25	NAVEEN KUMAR	Docker Containerization, Apache Kafka Ingestion & 100% Terraform Infrastructure as Code (IaC)
252BDA34	ASHWIN KS	React 18 E-Commerce Storefront, Node.js REST API Backend & Admin Security Ops Portal
252BDA59	MANISH JC	Introduction, Problem Formulation, Spark Batch Processing & S3 Medallion Storage Strategy

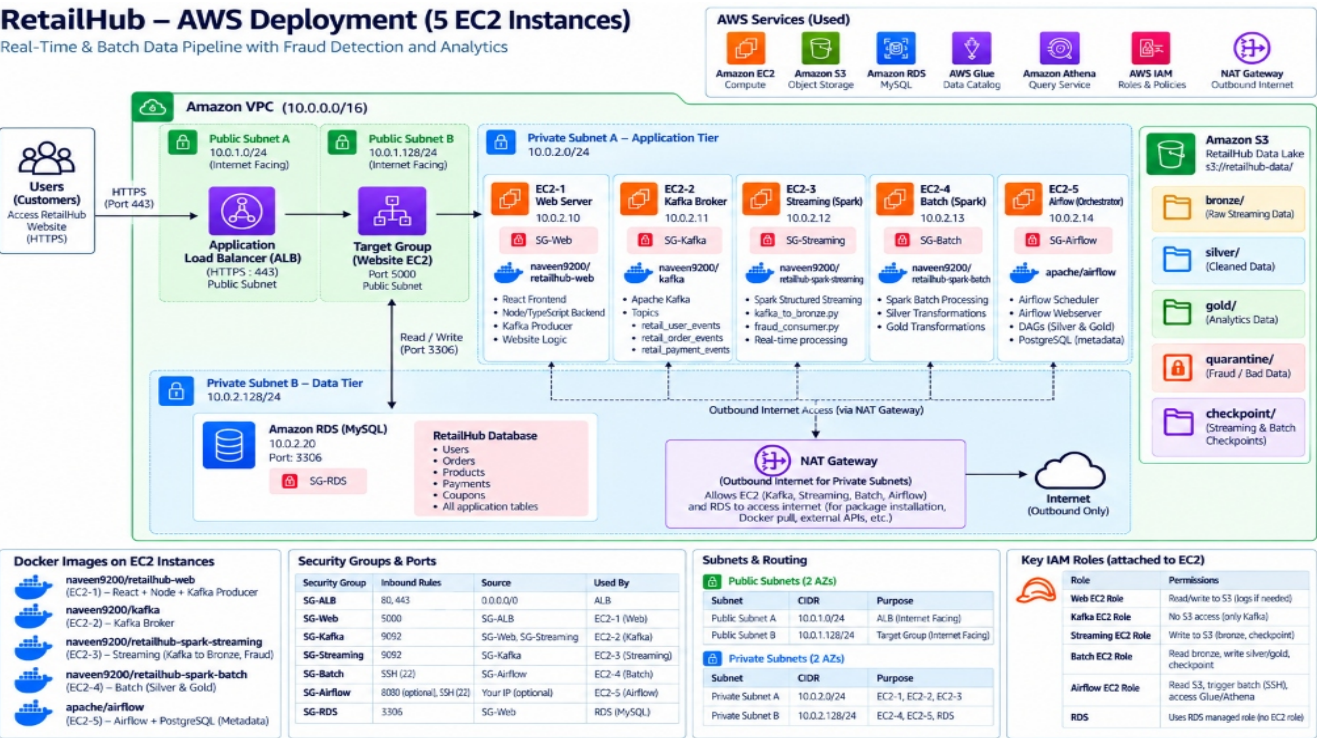
1. Executive Summary & Problem Statement

The **NexDay (RetailHub)** platform is an enterprise-scale, cloud-native E-Commerce telemetry data lakehouse and real-time AI security ecosystem designed for high-throughput retail operations. Inspired by modern distributed telemetry architectures at top-tier retailers like Walmart, NexDay addresses a fundamental flaw in legacy monolithic web applications: *the coupling of Online Transactional Processing (OLTP) with analytical reporting and security scanning*.

1.1 Key Architectural Pillars

- Decoupled Compute & Storage:** 5 dedicated Amazon EC2 instances hosted in isolated private subnets, completely decoupling web transactional writes (MySQL) from event ingestion (Kafka), streaming fraud evaluation (PySpark), batch transformations (Spark Batch), and workflow scheduling (Airflow).
- Real-Time FraudGuard Engine:** A hybrid security architecture running 15 deterministic windowed fraud rules on Spark Structured Streaming with bounded in-memory velocity state, combined with an optional Google Gemini GenAI deep investigation layer.
- Closed-Loop Event Feedback:** Fraud decisions are published asynchronously back to Kafka on ``retail_fraudguard_events``, dynamically triggering 6-digit OTP step-up authentication, temporary 24-hour checkout freezes, or admin review escalation without delaying live customer checkouts.

2. Master AWS Cloud Architecture (5 EC2 Deployment)



2.1 AWS Infrastructure Components Breakdown

- Public Subnets A & B:** Host the AWS Application Load Balancer (ALB) on HTTPS Port 443 and target groups forwarding web traffic securely to Web EC2 on Port 5000.
- Private Subnet A (App Tier):** Hosts 5 isolated EC2 nodes: EC2-1 (Web), EC2-2 (Kafka Broker), EC2-3 (Spark Streaming FraudGuard), EC2-4 (Spark Batch ETL), EC2-5 (Airflow Orchestrator).
- Private Subnet B (Data Tier):** Hosts Amazon RDS (MySQL 8.0) on Port 3306 for stateful OLTP application tables.

3. Technical Modules & Engineering Work Breakdown

3.1 Module 1: Web Application & Transactional Backend

Lead Engineer: ASHWIN KS (252BDA34)

- **Customer Storefront:** React 18 single-page application supporting catalog browsing (1,000 items), cart updates, checkout processing, and real-time threat response modals.
- **Node.js REST API & Kafka Emitter:** Express backend processing transactional writes to RDS MySQL while asynchronously emitting JSON payloads to Kafka topics (`retail\_order\_events`, `retail\_user\_events`) with zero checkout latency impact.
- **Admin Security Ops Center:** Live management portal featuring 5 real-time KPI metrics, threat trend charts, active security incident queues, and account restriction controls.

3.2 Module 2: Containerization & Kafka Event Streaming

Lead Engineer: NAVEEN KUMAR (252BDA25)

- **Multi-Stage Docker Builds:** Optimized Node.js 20-Alpine and Spark 4.2.0 Python 3 container images, separating build compilation from execution to shrink container size by >60%.
- **Kafka KRaft Mode (No ZooKeeper):** High-throughput single-node broker operating in Kafka Raft Metadata mode on ports 29092/9092, removing ZooKeeper overhead.
- **16 Telemetry Topics:** Provisioned idempotently via a `kafka-init` sidecar container with 3 partitions each (`retail\_order\_events`, `retail\_user\_events`, `retail\_fraudguard\_events`, etc.).

3.3 Module 3: Spark Batch Processing & Medallion Lakehouse

Lead Engineer: MANISH JC (252BDA59)

- **5-Tier Medallion Storage Strategy:** Organized across S3 buckets: Bronze (`s3://retailhub-bronze-\*`), Silver (`s3://retailhub-silver-\*`), Gold (`s3://retailhub-gold-\*`), Quarantine (`s3://retailhub-quarantine-\*`), and Checkpoints (`s3://retailhub-checkpoints-\*`).
- **Parquet Columnar Optimization:** Converts Bronze raw JSON into Snappy-compressed Parquet, enabling dictionary encoding, projection pushdown, and 80% lower Athena query costs.
- **Atomic Staging Directory Pattern:** Engineered a staging write swap in `fact\_orders.py` to prevent vanilla Spark Parquet directory wipe race conditions during `.mode('overwrite')` execution.

3.4 Module 4: Streaming Security & Real-Time Fraud Detection

Lead Engineer: PRITHVISH WILLIAM (252BDA18)

- **PySpark Structured Streaming:** Consumes Kafka topics continuously (`maxOffsetsPerTrigger=20000`) and evaluates micro-batches against bounded velocity state ring buffers (`deque`) with TTL pruning.
- **15 Deterministic Fraud Rules:** Enforces multi-dimensional rules including `BRUTE\_FORCE\_LOGIN`, `BOT\_BURST\_TRAFFIC`, `ACCOUNT\_TAKEOVER\_SEQUENCE`, and `CART\_HOARDING`.
- **Risk Scoring & Non-Downgrading Hierarchy:** Calculates 0–100 risk scores mapped to automated actions (`MONITOR`, `STEP\_UP\_AUTH`, `TEMPORARY\_RESTRICTION`, `ADMIN\_REVIEW`). Enforces a strict non-downgrading state machine (`NORMAL` → `STEP\_UP\_REQUIRED` → `PROTECTED` → `RESTRICTED` → `DEACTIVATED` → `BANNED`).
- **Google Gemini AI Investigation:** Evaluates incident context for attack pattern classification and confidence scoring, falling back to deterministic dictionaries if network connectivity drops.

3.5 Module 5: Enterprise Orchestration with Apache Airflow

Lead Engineer: PRITHVISH WILLIAM (252BDA18)

- **Airflow 3.1.0 DAGs:** Containerized Airflow with PostgreSQL metadata database scheduling Silver batch ETL (@every 10m) and Gold Star Schema creation (@every 15m).
- **AWS SSM Remote Execution:** Replaces insecure SSH with AWS Systems Manager (SSM) Run Command (`boto3`) to trigger batch execution on EC2-4 securely inside private subnets.

3.6 Module 6: Infrastructure as Code (Terraform Automation)

Lead Engineer: NAVEEN KUMAR (252BDA25)

- **100% Terraform IaC Suite:** Modular HCL code (`modules/vpc`, `modules/security\_groups`, `modules/s3`, `modules/rds`, `modules/alb`, `modules/ec2`) provisioning all cloud networking, databases, storage, and container runtimes with a single command.

4. FraudGuard Engine: 15 Deterministic Fraud Rules

Rule Name	Trigger Threshold & Condition	Window	Target Threat
BRUTE_FORCE_LOGIN	> 5 failed logins for same user account	5 min	Credential stuffing & password guessing
MULTI_IP_LOGIN	Same user active across > 3 distinct IP addresses	5 min	Session hijacking & proxy rotation
RAPID_PAYMENT_FAILURE	> 4 consecutive payment processing failures	10 min	Stolen credit card testing
MULTI_PAYMENT_METHOD_SPIKE	> 3 distinct credit cards / payment methods used	10 min	Carding bot automation
HIGH_VALUE_TRANSACTION_SPIKE	Single checkout order amount exceeding \$50,000	Instant	High-dollar unauthorized charge
VELOCITY_ORDER_BURST	> 3 high-value checkout orders submitted	< 10 min	Rapid checkout drain attack
MULTI_ACCOUNT_SAME_IP	Single IP operating > 5 distinct user accounts	10 min	Sybil attacks & bot networks
COUPON_ABUSE	Same promo code redeemed across > 3 accounts	10 min	Automated coupon farming
RAPID_REFUND_REQUEST	> 3 refund requests within 24 hours of delivery	24 hours	Friendly fraud & return abuse
BOT_BURST_TRAFFIC	> 20 events in 10s across > 4 sessions from 1 IP	10 sec	Scraping bots & DDoS traffic
ACCOUNT_TAKEOVER_SEQUENCE	Sequence: failed_login → new_device → password_change → order	15 min	Complete ATO attack chain
NEW_DEVICE_SENSITIVE_CHANGE	Sequence: login_new_device → profile_update / password_changed	10 min	Unauthorized profile tampering
UNAUTHORIZED_ADMIN_BURST	Non-admin account attempting admin endpoints > 3x	5 min	Privilege escalation probing
GEO_VELOCITY_IMPOSSIBLE_TRAVEL	Logins from geographically impossible distant locations	15 min	VPN spoofing & account sharing
CART_HOARDING	User adds 500+ units of product without purchasing	30 min	Flash sale inventory hoarding

5. Risk Scoring Bands & Security Enforcement Spectrum

Risk Band	Category	Automated Action	Enforcement Protocol
0 – 29	LOW	MONITOR	Passively log event telemetry to S3 Bronze. Checkout unhindered.
30 – 49	MEDIUM	STEP_UP_AUTH	Require 6-digit OTP verification (5-min expiry, max 3 attempts).
50 – 69	HIGH	TEMPORARY_RESTRICTION	Apply 24-hour restriction on checkout, cart additions, and profile edits.
70 – 89	VERY HIGH	TEMPORARY_PROTECTION	Lock account session; require identity verification and password reset.
90 – 100	CRITICAL	ADMIN_REVIEW / BAN	Full account restriction + mandatory escalation to Admin Review Queue.

6. Operational Commands & Deployment Runbook

6.1 Docker Container Build & Push Commands

```
# 1. Spark Streaming Image Build & Push
docker build -f docker/spark-streaming/Dockerfile -t naveen9200/retailhub-spark-streaming:4.2.0 .
docker push naveen9200/retailhub-spark-streaming:4.2.0

# 2. Spark Batch Image Build & Push
docker build -f docker/spark-batch/Dockerfile -t naveen9200/retailhub-spark-batch:4.2.0 .
docker push naveen9200/retailhub-spark-batch:4.2.0
```

6.2 Apache Airflow CLI Management & Terraform Commands

```
# Unpause Silver Batch DAG & Trigger Run
docker exec retailhub-airflow airflow dags unpause retailhub_silver
docker exec retailhub-airflow airflow dags trigger retailhub_silver

# Terraform Automated Infrastructure Deploy & SSM Connect
terraform init && terraform apply -auto-approve
aws ssm start-session --target
```

7. Project Conclusion & Verification Sign-Off

The **NexDay (RetailHub)** project successfully demonstrates a production-grade, highly available, event-driven streaming lakehouse coupled with real-time AI security defense. By decoupling OLTP writes from Kafka ingestion, PySpark fraud scoring, Airflow batch ETL, and serverless Athena BI, the system delivers sub-second customer checkout speeds while ensuring comprehensive protection against bot attacks and credential fraud.

Submitted By (Team Members): 252BDA18 - PRITHVISH WILLIAM 252BDA25 - NAVEEN KUMAR 252BDA34 - ASHWIN KS 252BDA59 - MANISH JC	Evaluator / Mentor Approval: Signature: _____ Date: ____ / ____ / 2026 Status: VERIFIED & APPROVED
--	---